

VirtuEx 시스템 감사 보고서 (9차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 9차 감사 (종합 정기 감사) 작성일: 2026-03-07 작성: 시스템 감사팀

1. 개요

9차 감사는 VirtuEx 프로젝트 전체를 대상으로 한 **종합 정기 감사**입니다. 8차 감사(2026-03-04) 이후 수정된 사항을 검증하고, 백엔드 8개 마이크로서비스, 프론트엔드 Next.js 15 애플리케이션, 인프라/Docker 구성을 대상으로 **보안, 코드 품질, 접근성, 성능, i18n, 아키텍처** 전 영역을 코드 레벨에서 재검사했습니다.

1.1 감사 범위

영역	검사 항목	신규 이슈
보안 — 프론트엔드	XSS, 파일 업로드, HTML 살균	3건
보안 — 백엔드	DTO 검증, 인가, MIME 화이트리스트	4건
코드 품질/버그	useEffect 의존성, PnL 표시, 상태 관리	4건
접근성 (WCAG)	모달, ARIA, 키보드 접근	4건
i18n	하드코딩 텍스트, t() 미사용	4건
성능	리사이즈 throttle, 메모이제이션	2건
SEO	동적 메타데이터	1건
UX	삭제 네비게이션, 낙관적 UI, 로딩	3건
인프라 — Docker/Compose	헬스체크, Kafka, Prometheus	4건
인프라 — CI/CD	Dockerfile 경로, Trivy, Prisma	3건
인프라 — 환경변수	.env.example 누락/불일치	2건
인프라 — 서비스 통신	localhost 하드코딩, 재시도 로직	2건
인프라 — 데이터베이스	파티셔닝, 보존 정책, UUID 타입	3건
인프라 — 모니터링	Alertmanager, Grafana 대시보드	2건
인프라 — 스크립트	OS 결합, kill -9, perl 의존	3건
합계		48건

1.2 심각도 분류

심각도	건수
상 (Critical)	4
중 (Medium)	26
하 (Low)	18

2. 상 (Critical) — 4건

#1. XSS: 커뮤니티 게시물 HTML 미살균 렌더링

- 심각도: 상
- 영역: 프론트엔드 보안
- 파일: `frontend/src/app/(main)/community/[id]/page.tsx:344`
- 설명: `dangerouslySetInnerHTML={{ __html: post.content }}` 로 사용자 작성 HTML(TipTap 에디터)을 그대로 렌더링합니다. `<img onerror="...">`, `<svg onload="...">`, `<a href="javascript:...">` 등을 통한 XSS 공격이 가능합니다.
- 권장 수정: `DOMPurify` 라이브러리를 설치하고 `DOMPurify.sanitize(post.content)` 로 살균 후 렌더링

#2. 채팅 `markRead useEffect` 무한 재실행

- 심각도: 상
- 영역: 코드 품질/버그
- 파일: `frontend/src/components/chat/MessageArea.tsx:130`
- 설명: `useEffect` 의 의존성 배열에 `markRead` 가 포함되어 있으나, `useMarkRoomRead()` 가 매 렌더마다 새 참조를 생성합니다. `ref` 가드로 API 중복 호출은 방지되지만, `Effect` 자체는 매 렌더 사이클마다 재실행되어 불필요한 연산이 발생합니다.
- 권장 수정: `markRead.mutate` 를 `ref` 로 저장하거나 의존성 배열에서 제거

#3. Redis 헬스체크 비밀번호 누락

- 심각도: 상
- 영역: 인프라 — Docker
- 파일: `docker-compose.yml:47`
- 설명: Redis는 `--requirepass ${REDIS_PASSWORD:-redis}` 로 인증을 요구하지만, 헬스체크는 `redis-cli ping` 으로 비밀번호 없이 실행합니다. Redis 6+에서는 인증 없는 PING에 NOAUTH 에러를 반환하므로 헬스체크가 항상 실패할 수 있습니다.
- 권장 수정: `test: ['CMD', 'redis-cli', '-a', '${REDIS_PASSWORD:-redis}', 'ping']`

#4. CI 컨테이너 스캔 Dockerfile 경로 오류

- 심각도: 상
- 영역: 인프라 — CI/CD
- 파일: `.github/workflows/ci.yml:134`
- 설명: `docker build -t virtutex-scan:latest -f docker/Dockerfile .` 로 참조하지만, 실제 Dockerfile은 `backend/services/api-gateway/Dockerfile` 등 서비스별 위치에 있습니다. `docker/Dockerfile` 은 존재하지 않으므로 `container-scan` 작업이 항상 실패합니다.
- 권장 수정: 올바른 Dockerfile 경로로 수정하거나 서비스별 스캔 구성

3. 중 (Medium) — 26건

3.1 프론트엔드 보안 (2건)

#	항목	파일	설명
---	----	----	----

#5	RichEditor 이미지 업로드 MIME/크기 미검증	RichEditor.tsx:67-77	FileReader로 아무 파일이나 base64 삽입. SVG+script 태그로 XSS 가능
#6	커뮤니티 첨부파일 타입/크기 미검증	community/new/page.tsx:107-111	UI에 "max 10MB" 표시하지만 코드에서 미적용. 파일 타입 제한 없음

3.2 백엔드 보안 (4건)

#	항목	파일	설명
#7	12개 컨트롤러 인라인 타입 → DTO 검증 우회	portfolio/internal.controller.ts 외	금융 엔드포인트 (reserveFunds, settleBuy 등) 포함. ValidationPipe whitelist 무효화
#8	UserSettingsProxy에서 일반 유저 시스템 설정 수정 가능	user-settings-proxy.controller.ts:14	JwtAuthGuard만 적용. AdminRolesGuard 누락으로 인증된 모든 유저가 시스템 설정 PUT 가능
#9	News scrape 엔드포인트 AdminRolesGuard 누락	news-proxy.controller.ts:49-63	아무 인증된 유저가 수동 스크래핑 트리거 가능
#10	첨부파일 업로드 MIME 화이트리스트 없음	community.controller.ts:450	.exe, .html 등 실행 파일 업로드 가능. Content-Disposition도 미설정

3.3 코드 품질/버그 (2건)

#	항목	파일	설명
#11	HoldingCard 음수 PnL 부호 미표시	HoldingCard.tsx:76	Math.abs 사용 후 음수에 '-' 미추가. 손실이 \$500으로 표시됨
#12	PortfolioHistoryChart 매 refetch마다 랜덤 데이터 재생성	PortfolioHistoryChart.tsx:34-65	totalValue 변경(10초 폴링)시 차트 데이터가 매번 달라짐

3.4 접근성 (3건)

#	항목	파일	설명
#13	채팅 확인 모달 role/aria-modal/포커스트랩 없음	MessageArea.tsx:435-509	leave/kick/delete 모달. 키보드로 모달 뒤 요소 접근 가능
#14	RichEditor 톨바 aria-label/aria-pressed 없음	RichEditor.tsx:82-103	아이콘 전용 버튼. 스크린리더에서 기능 식별 불가
#15	채팅 삭제 버튼 키보드 접근 불가	MessageBubble.tsx:108-113	opacity-0 group-hover:opacity-100만 적용. focus:opacity-100 없음

3.5 i18n (1건)

#	항목	파일	설명
#16	하드코딩 한/영 텍스트 (t() 미사용)	community/[id]/page.tsx:335 외	'삭제'/'Delete', 'Participants', 'Admin' 등 인라인 처리

3.6 성능 (1건)

#	항목	파일	설명
#17	CandlestickChart 리사이즈 throttle 미적용	CandlestickChart.tsx:162-168	window.resize마다 chart.applyOptions 호출. 초당 수십 회 레이아웃 발생

3.7 UX (1건)

#	항목	파일	설명
#18	커뮤니티 삭제 실패해도 목록 페이지로 이동 가능	community/[id]/page.tsx:245-249	빈 catch로 에러 무시. 삭제 실패 여부 사용자 인지 불가

3.8 인프라 — Docker/Compose (2건)

#	항목	파일	설명
#19	Kafka ADVERTISED_LISTENERS localhost 하드코딩	docker-compose.yml:75	컨테이너화 시 서비스 간 통신 불가
#20	Prometheus 데이터 볼륨 미설정	docker-compose.yml:192-219	재시작 시 메트릭 소실

3.9 인프라 — CI/CD (2건)

#	항목	파일	설명
#21	Trivy 액션 @master 참조 (버전 미고정)	ci.yml:137	공급망 공격 위험. SHA 또는 특정 버전 태그로 고정 필요
#22	CI Prisma generate 경로 오류	ci.yml:64-69	services/*/ → backend/services/*/이어야 함

3.10 인프라 — 환경변수 (2건)

#	항목	파일	설명
#23	.env.example 환경변수 5개 누락	.env.example	OUTBOX_POLL_INTERVAL_MS, SMS_VERIFIED_TTL 등
#24	.env.example REDIS_PASSWORD 빈값 ↔ docker-compose 기본값 불일치	.env.example:28	빈 값으로 복사 시 Redis 인증 에러

3.11 인프라 — 서비스 통신 (2건)

#	항목	파일	설명
#25	PriceSubscriberService localhost 하드코딩	price- subscriber.service.ts:49	SERVICE_HOST 환경변수 무 시
#26	getMarketPrice() 재시도 로직 미 적용	order.service.ts:862-876	다른 금융 호출은 withRetry 사 용하지만 이것만 누락

3.12 인프라 — 데이터베이스 (3건)

#	항목	파일	설명
#27	PriceHistory 테이블 파티셔닝/보존 정책 없음	market- data/schema.prisma:30-43	초당 수십 건 삽입. 무한 성장으 로 인덱스 성능 저하
#28	PageView 테이블 데이터 보존 정책 없음	user- auth/schema.prisma:217- 226	트래픽 증가 시 테이블 비대화
#29	CommunityPost.authorId @db.UUID 및 FK 누락	user- auth/schema.prisma:253	Comment.authorId는 @db.UUID+FK 있음. 불일치

3.13 인프라 — 모니터링 (2건)

#	항목	파일	설명
#30	Prometheus alertmanager 미설정	prometheus.yml	알림 규칙 있지만 수신자(Slack/이메일) 연동 없음
#31	Grafana 대시보드 프로비저닝 없 음	grafana/provisioning/	재시작 시 수동 대시보드 소실

3.14 인프라 — 스크립트 (2건)

#	항목	파일	설명
#32	start-all.sh macOS 전용 명령어	start- all.sh:131,265	brew, lsof 사용. Linux에서 예러
#33	kill -9 강제 종료	start-all.sh:245	graceful shutdown 불가. 진행 중 트랜잭션/메 시지 유실 가능

4. 하 (Low) — 18건

#	영역	항목	파일
#34	FE 버그	useSearchUsers 빈 쿼리에도 API 호출	useChat.ts:329-344
#35	FE 접근 성	온라인 상태 점 스크린리더 텍스트 없음	MessageArea.tsx:197

#36	FE SEO	커뮤니티 상세 동적 metadata 없음	community/[id]/page.tsx
#37	FE UX	채팅 낙관적 UI 없음 (전송 지연 체감)	MessageArea.tsx:148-155
#38	FE UX	댓글 제출 로딩 인디케이터 없음	community/[id]/page.tsx:390-397
#39	FE 성능	messages flatMap 매 렌더 새 배열 생성	MessageArea.tsx:96
#40	FE i18n	첨부파일 업로드 안내 텍스트 i18n 미적용	community/new/page.tsx:192
#41	FE i18n	Header "Admin" 라벨 하드코딩	Header.tsx:250,404
#42	FE i18n	"Participants" 라벨 하드코딩	MessageArea.tsx:222
#43	BE	x-user-role 헤더 기반 인가 (InternalAuthGuard 경감)	community.controller.ts:264 외
#44	BE	프로필 수정 전화번호 정규식 미검증	profile.controller.ts:62
#45	BE	비밀번호 변경 복잡도 검증 없음	profile.controller.ts:103
#46	BE	Portfolio userId UUID 형식 미검증	portfolio.controller.ts:172-178
#47	BE	CreatePostDto title/content MaxLength 없음	community.dto.ts:10-22
#48	BE	resendSms DTO 없이 raw Body 사용	auth.controller.ts:100,208
#49	인프라	Kafka UI 리소스 제한 미설정	docker-compose.yml
#50	인프라	Kafka 토픽 4개 자동 생성 누락	start-all.sh:324
#51	인프라	프론트엔드 로그 perl 의존성	start-all.sh:454

5. 긍정적 평가 사항

8차 감사 이후 확인된 개선 사항 및 우수한 구현:

- **InternalAuthGuard**: 8개 마이크로서비스 전체에 클래스 레벨 적용. `timingSafeEqual` 사용
- **금융 트랜잭션**: `balance.service.ts`의 모든 잔액 변동에 `$transaction + FOR UPDATE` 락 적용
- **시크릿 관리**: 소스코드에 하드코딩된 비밀번호/API 키 없음. 모두 환경변수 로드
- **ValidationPipe**: 8개 서비스 모두 `whitelist: true, forbidNonWhitelisted: true, transform: true` 설정
- **에러 처리**: 글로벌 예외 필터가 스택 트레이스를 제거하고 일반 메시지 반환
- **CSRF 보호**: 리프레시 토큰에 `httpOnly, sameSite: 'lax', secure` 쿠키 적용
- **레이트 리밋**: 로그인, 회원가입, SMS 등 주요 엔드포인트에 Throttle 가드 적용
- **페이지네이션 제한**: 모든 목록 엔드포인트에 max page size 적용
- **경로 순회 방지**: 파일 서빙에 `path.basename()` 및 null byte 검사 적용
- **버튼 UI 개선**: btn-filled/btn-outline/btn-ghost 텍스트 적용으로 시각적 깊이감 향상
- **새로고침 UX 통일**: 포트폴리오/뉴스/리더보드 전체 동일한 최소 1초 로딩 패턴 적용
- **CDN 폰트 FOIT 방지**: preconnect 적용

6. 최우선 조치 권장 순서

순위	#	항목	이유
1	#1	XSS HTML 살균	사용자 데이터 탈취 가능. 보안 위험 최상
2	#8	Settings 권한 갭	일반 유저가 시스템 설정 변경 가능
3	#2	markRead 무한 루프	성능/안정성 즉시 영향
4	#7	금융 DTO 검증 누락	금융 엔드포인트 입력값 무검증
5	#10	MIME 화이트리스트	실행 파일 업로드를 통한 공격 가능
6	#3	Redis 헬스체크	인프라 정상 동작 보장
7	#4	CI Dockerfile 경로	보안 스캔 파이프라인 복구

7. 이전 감사 대비 추이

차수	상	중	하	합계	비고
6차	8	32	35	75	최초 종합 감사
7차	5	29	28	62	6차 47건 수정 확인
8차	3	20	19	42	7차 57건 수정 확인
9차	4	26	18	48	채팅/커뮤니티 신규 기능 포함

9차에서 건수가 소폭 증가한 것은 커뮤니티 자유게시판, 채팅 기능 등 신규 기능이 추가되었으며, 인프라/아키텍처 영역을 더 깊이 검사한 결과입니다.